

Authentication Bypasses

The Scenario

You are resetting your password, but doing it from a location or device that your provider does not recognize. So you need to answer the security questions you set up. The other issue is that those security questions are also stored on another device (not with you) and you don't remember them.

You have already provided your username/email and opted for the alternative verification method.

Verify Your Account by answering the questions below:

What is the name of your favorite teacher?

What is the name of the street you grew up on?

Submit

You are resetting your password, but doing it from a location or device that your provider does not recognize. So you need to answer the security questions you set up. The other issue is that those security questions are also stored on another device (not with you) and you don't remember them.

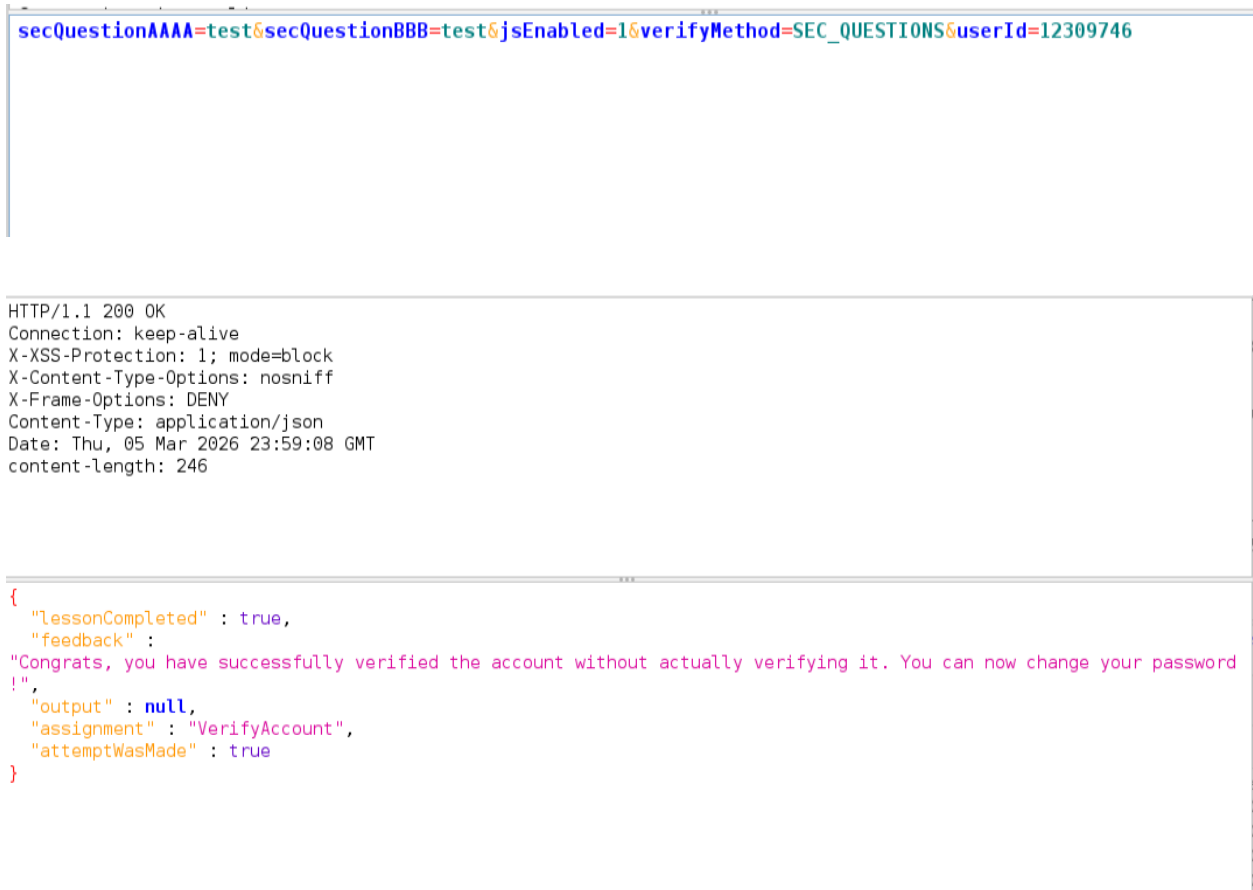
You have already provided your username/email and opted for the alternative verification method.

Open ZAP and intercept the request

The screenshot shows a web browser window on the left and a ZAP proxy interface on the right. The browser window displays a 'Verify Your Account' page with two security questions: 'What is the name of your favorite teacher?' and 'What is the name of the street you grew up on?'. The ZAP interface shows a list of intercepted requests, with the selected request being a POST to 'http://127.0.0.1:8080/WebGoat/auth-bypass/verify-account'. The request body is visible in the right pane, showing a JSON payload with fields like 'securityQuestion0', 'securityQuestion1', 'verifyMethod', and 'userId'.

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size	Resp. Bo...	Highest Al...	Note	Tags
9	Pr...	3/5/26, 4:57:24 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	3...	7,350	bytes			
10	Pr...	3/5/26, 4:57:24 ...	GET	http://127.0.0.1:8080/WebGoat/AuthBypa...	200	OK	4...	6,990	bytes			
11	Pr...	3/5/26, 4:57:25 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	110	bytes			JSON
12	Pr...	3/5/26, 4:57:25 ...	GET	http://127.0.0.1:8080/WebGoat/service/hi...	200	OK	2...	390	bytes			
13	Pr...	3/5/26, 4:57:25 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	278	bytes			JSON
14	Pr...	3/5/26, 4:57:29 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	278	bytes			JSON
15	Pr...	3/5/26, 4:57:29 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,350	bytes			
16	Pr...	3/5/26, 4:57:31 ...	POST	http://127.0.0.1:8080/WebGoat/auth-bypa...	200	OK	2...	158	bytes			JSON
18	Pr...	3/5/26, 4:57:34 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	158	bytes			JSON
19	Pr...	3/5/26, 4:57:34 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,350	bytes			
20	Pr...	3/5/26, 4:57:39 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	158	bytes			JSON
21	Pr...	3/5/26, 4:57:39 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	2...	7,350	bytes			

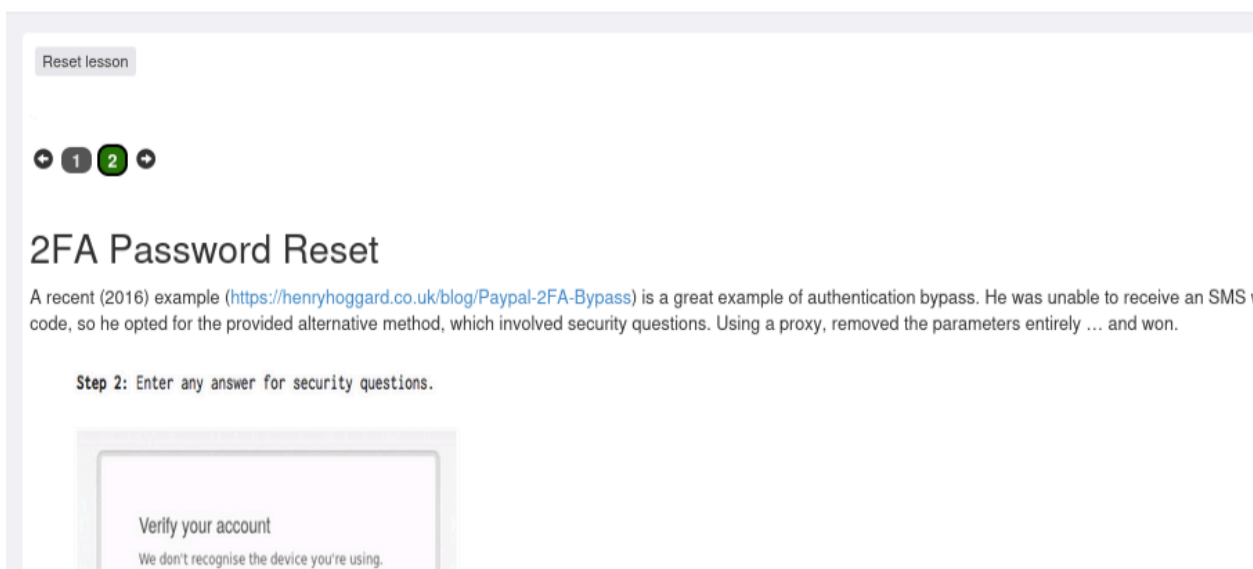
Open the request in the request editor and change the names of the secQuestions



The screenshot shows a web browser's developer tools with the 'Network' tab selected. A request is highlighted, and its details are expanded. The request URL is `secQuestionAAAA=test&secQuestionBBB=test&jsEnabled=1&verifyMethod=SEC_QUESTIONS&userId=12309746`. The response status is `HTTP/1.1 200 OK`. The response headers include `Connection: keep-alive`, `X-XSS-Protection: 1; mode=block`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Content-Type: application/json`, `Date: Thu, 05 Mar 2026 23:59:08 GMT`, and `content-length: 246`. The response body is a JSON object:

```
{  "lessonCompleted": true,  "feedback": "Congrats, you have successfully verified the account without actually verifying it. You can now change your password!",  "output": null,  "assignment": "VerifyAccount",  "attemptWasMade": true}
```

Authentication Bypasses



The screenshot shows a web application interface for a 2FA Password Reset. At the top, there is a 'Reset lesson' button. Below it, there are two circular progress indicators, the second of which is highlighted with a green background. The main heading is '2FA Password Reset'. Below the heading, there is a paragraph of text: 'A recent (2016) example (<https://henryhoggard.co.uk/blog/Paypal-2FA-Bypass>) is a great example of authentication bypass. He was unable to receive an SMS code, so he opted for the provided alternative method, which involved security questions. Using a proxy, removed the parameters entirely ... and won.'

Below the text, there is a section titled 'Step 2: Enter any answer for security questions.' and a screenshot of a mobile device screen showing a 'Verify your account' message: 'We don't recognise the device you're using.'

Password Reset

➤ 1 2 3 4 5 6 7 ➤

Email functionality with WebWolf

Let's first do a simple assignment to make sure you are able to read e-mails with WebWolf, first start WebWolf (see [here](#)) In the reset page below send an e-mail to `username@webgoat.org` (part behind the @ is not important) Open WebWolf and read the e-mail and login with your username and the password provided in the e-mail.

Account Access

@

Email

Password

Access

Forgot your password?

Let's first do a simple assignment to make sure you are able to read e-mails with WebWolf, first start WebWolf (see [here](#)) In the reset page below send an e-mail to `username@webgoat.org` (part behind the @ is not important) Open WebWolf and read the e-mail and login with your username and the password provided in the e-mail.

Email functionality with WebWolf

Let's first do a simple assignment to make sure you are able to read e-mails with WebWolf, first start WebWolf (see [here](#)) In the reset page below send an e-mail to `username@webgoat.org` (part behind the @ is not important) Open WebWolf and read the e-mail and login with your username and the password provided in the e-mail.

Account Access

@

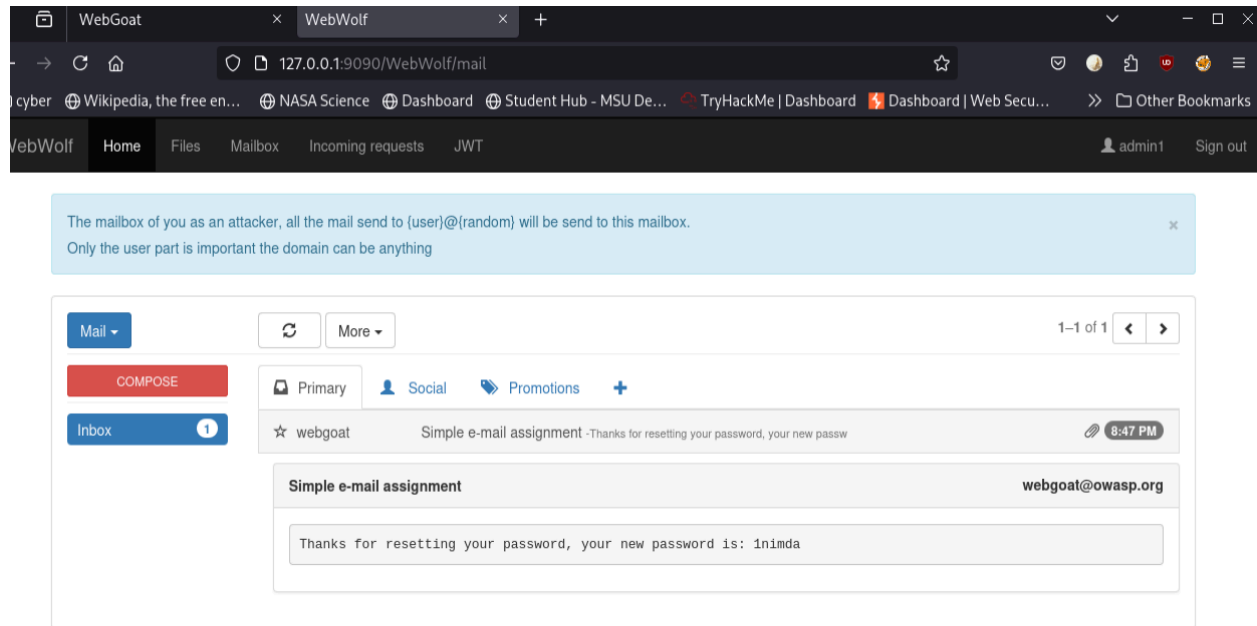
admin1@webgoat

Password

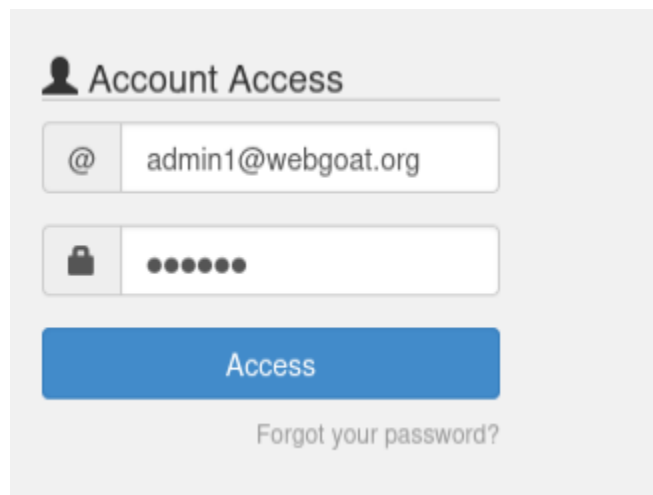
Access

Forgot your password?

Send the password reset email to webwolf



We get a new password and can paste it in to access the account on webgoat



Email functionality with WebWolf

Let's first do a simple assignment to make sure you are able to read e-mails with WebWolf, first start WebWolf (see [here](#)) In the reset page below send an e-mail to `username@webgoat.org` (part behind the @ is not important) Open WebWolf and read the e-mail and login with your username and the password provided in the e-mail.




Account Access

@ Email


 Password

Access

Forgot your password?

Congratulations. You have successfully completed the assignment.

(The lesson is complete but I don't know why the '2' on the navigation is still red)

Assignment

Users can retrieve their password if they can answer the secret question properly. There is no lock-out mechanism on this 'Forgot Password' page. Your username is 'webgoat' and your favorite color is 'red'. The goal is to retrieve the password of another user. Users you could try are: "tom", "admin" and "larry".

[Sign up](#)
[Login](#)

WebGoat Password Recovery

Your username

Username

What is your favorite color?

Answer security question

Submit

We know the users to try are tom, admin, and larry. After trying different combinations with different colors, the answer is tom, purple

Reset lesson

➡ 1 2 3 4 5 6 7 ➡

Security questions

This has been an issue and still is for a lot of websites, when you lost your password the website will ask you for a security question which you answered during the sign up process. Most of the time this list contains a fixed number of questions and which sometimes even have a limited set of answers. In order to use this functionality a user should be able to select a question by itself and type in the answer as well. This way users will not share the question which makes it more difficult for an attacker.

One important thing to remember the answers to these security question(s) should be treated with the same level of security which is applied for storing a password in a database. If the database leaks an attacker should not be able to perform password reset based on the answer of the security question.

Users share so much information on social media these days it becomes difficult to use security questions for password resets, a good resource for security questions is: <http://goodsecurityquestions.com/>

Assignment

Users can retrieve their password if they can answer the secret question properly. There is no lock-out mechanism on this 'Forgot Password' page. Your username is 'webgoat' and your favorite color is 'red'. The goal is to retrieve the password of another user. Users you could try are: "tom", "admin" and "larry".

✓

[Sign up](#) [Login](#)

WebGoat Password Recovery

Your username

What is your favorite color?

Congratulations. You have successfully completed the assignment.

Reset lesson

➡ 1 2 3 4 5 6 7 ➡

The Problem with Security Questions

While Security Questions may at first seem like a good way to do authentication, they have some big problems.

The "perfect" security question should be hard to crack, but easy to remember. Also the answer needs to be fixed, so it must not be subject to change.

There are only a handful of questions which satisfy these criteria and practically none which apply to anybody.

If you have to pick a security question, we recommend not answering them truthfully.

To further elaborate on the matter, there is a small assignment for you: There is a list of some common security questions down below. If you choose one, it will show to you why the question you picked is not really as good as one may think.

When you have looked at two questions the assignment will be marked as complete.

What is your favorite animal? ▼

check

Choose a strong security question

Reset lesson

➡ 1 2 3 4 5 6 7 ➡

The Problem with Security Questions

While Security Questions may at first seem like a good way to do authentication, they have some big problems.

The "perfect" security question should be hard to crack, but easy to remember. Also the answer needs to be fixed, so it must not be subject to change.

There are only a handful of questions which satisfy these criteria and practically none which apply to anybody.

If you have to pick a security question, we recommend not answering them truthfully.

To further elaborate on the matter, there is a small assignment for you: There is a list of some common security questions down below. If you choose one, it will show to you why the question you picked is not really as good as one may think.

When you have looked at two questions the assignment will be marked as complete.

✓

What is the name of the person you first kissed? ▼ check

Optional[Can be figured out through social media, or even guessed by trying the most common names.]

I chose "What is the name of the person you first kissed?"

Creating the password reset link

When creating a password reset link you need to make sure:

- It is a unique link with a random token
- It can only be used once
- The link is only valid for a limited amount of time.

Sending a link with a random token means an attacker cannot start a simple DOS attack to your website by starting to block users. The link should not be usable more than once which makes it impossible to change the password again. The time out is necessary to restrict the attack window, having a link opens up a lot of possibilities for the attacker.

Assignment

Try to reset the password of Tom (tom@webgoat-cloud.org) to your own choice and login as Tom with that password. Note: it is not possible to use OWASP ZAP for this lesson, also browsers might not work, command line tools like `curl` and the like will be more successful for this attack.

Tom always resets his password immediately after receiving the email with the link.

Account Access

@ Email

Password

Access

Forgot your password?

Send a password reset

Account Access

Forgot your password?

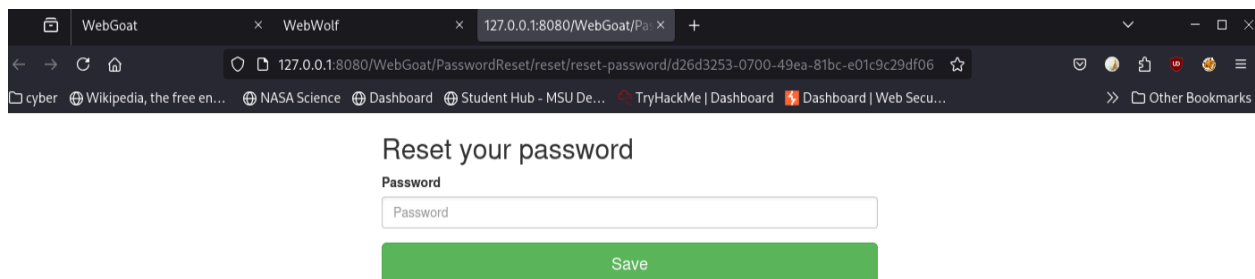
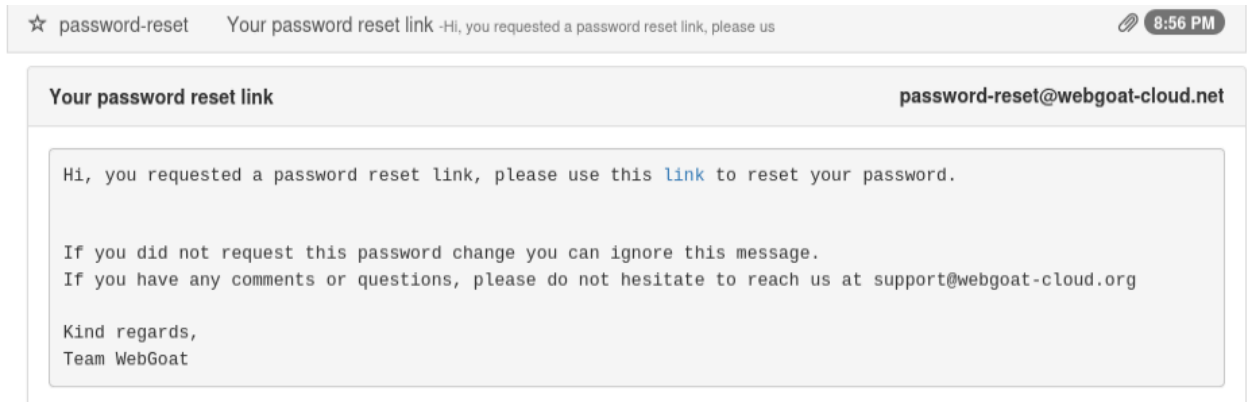
Email address you use to log in to your account
We'll send you an email with instructions to choose a new password.

@ admin1@webgoat.org

Continue

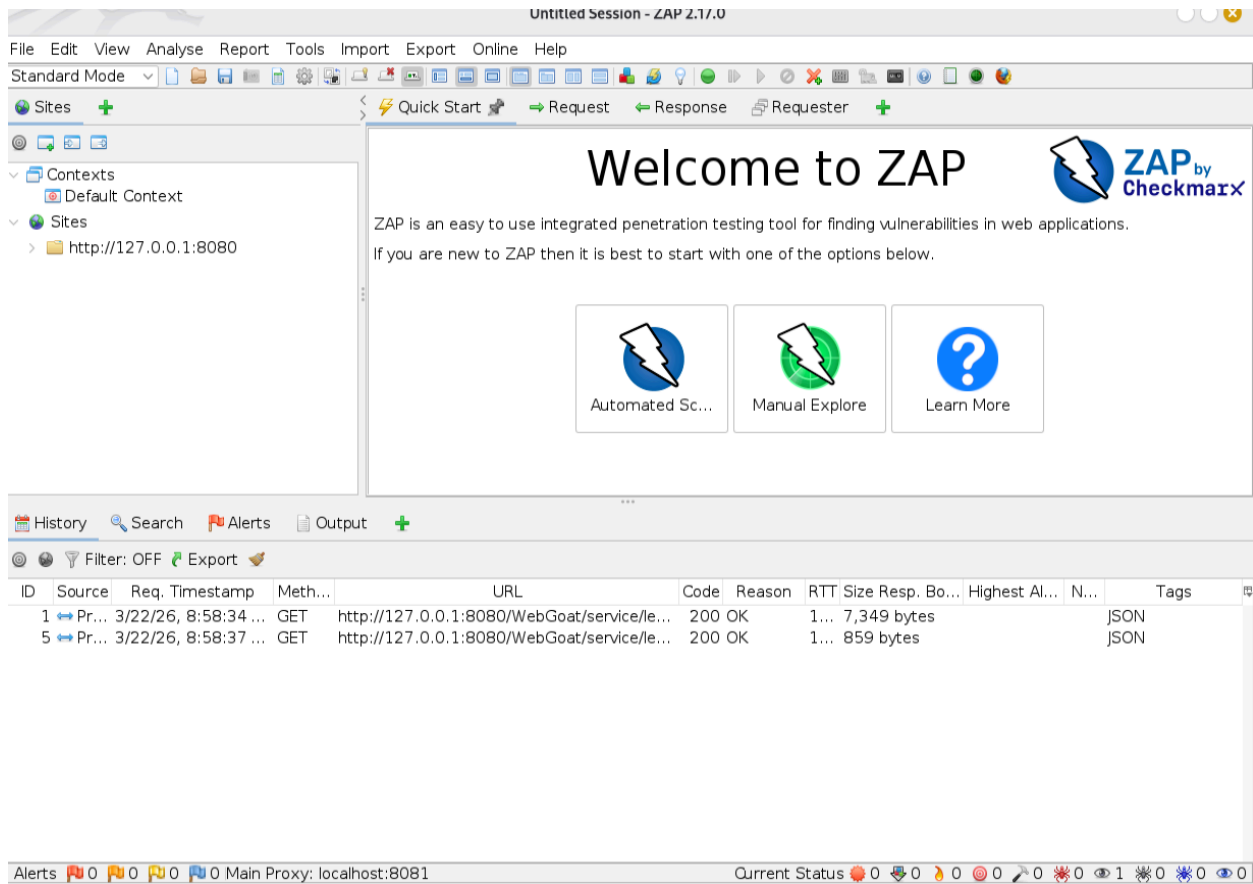
Account Access

We get a link



The URL is
<http://127.0.0.1:8080/WebGoat/PasswordReset/reset/reset-password/d26d3253-0700-49ea-81bc-e01c9c29df06>

Start ZAP



Send a request to tom's email on webgoat

 **Account Access**

Forgot your password?

Email address you use to log in to your account
We'll send you an email with instructions to choose a new password.

@

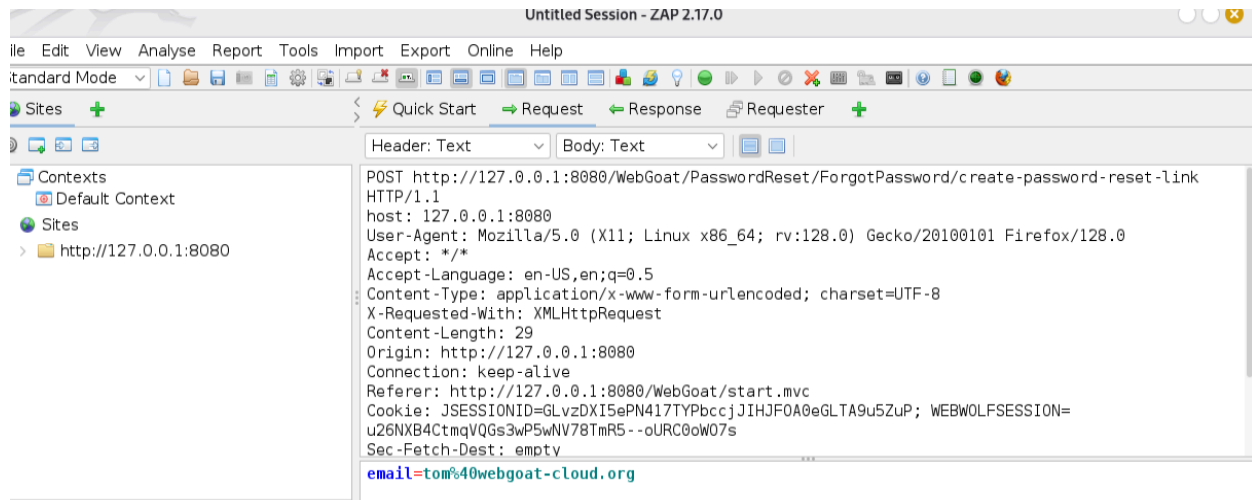
Email

Continue

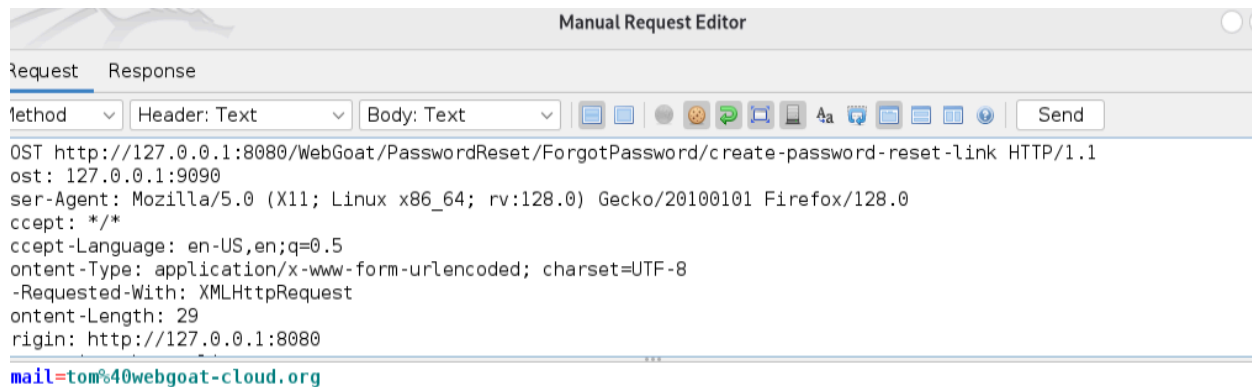
Account Access

An e-mail has been send to tom@webgoat-cloud.org

Intercept it with ZAP



Change the localhost port to 9090 in the manual request editor



Send it

Manual Request Editor

Request Response

Header: Text Body: Text Send

HTTP/1.1 200 OK
Connection: keep-alive
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Content-Type: application/json
Date: Mon, 23 Mar 2026 03:02:43 GMT
Content-Length: 197

```
{  
  "lessonCompleted" : true,  
  "feedback" : "An e-mail has been send to tom@webgoat-cloud.org",  
  "output" : null,  
  "assignment" : "ResetLinkAssignmentForgotPassword",  
  "attemptWasMade" : true  
}
```

ind: ↑ ↓ No matches Time: 263 ms Body Length: 197 Total Length: 419 bytes

We can see incoming requests in webwolf

This is by no means a substitution of httpd but it offers enough functionality to callback to a safe environment and does not require you to host your own httpd server on your local machine.

Requests

- 2026-03-23T02:46:03.237044931Z | /
- 2026-03-23T03:07:32.994076069Z | /WebGoat/PasswordReset/ForgotPassword/create-password-reset-link
- 2026-03-23T03:07:39.204516198Z | /WebGoat/PasswordReset/ForgotPassword/create-password-reset-link
- 2026-03-23T03:08:35.527647806Z | /WebGoat/PasswordReset/ForgotPassword/create-password-reset-link
- 2026-03-23T03:08:46.434482442Z | /WebGoat/PasswordReset/ForgotPassword/create-password-reset-link

Im encountering some issue here none of the requests point to anything useful, but I imagine the solution is to take the uri from the request that actually works and give a password of your choice and then login, but of course every link I have here is a place holder because apparently

WebWolf

This is the general error page of WebWolf. It applies for all 404, 500 etc messages.

Sometimes you will end up on this page on purpose because of a fake call to WebGoat which is redirected to WebWolf. In that situation, you are probably interested in seeing the detail of the request. Login to WebWolf and check the incoming requests.

Date: Sun Mar 22 21:14:04 MDT 2026

Path: /WebGoat/PasswordReset/ForgotPassword/create-password-reset-link

Status:404

Its 404? I did everything how you should do it but it still doesn't work, maybe because its an outdated instance of webgoat/webwolf....

Moving on to secure passwords

Reset lesson

➤

1

2

3

4

5

6

➤

How long could it take to brute force your password?

In this assignment you have to type in a password which is strong enough (at least 4/4).

After you finished this assignment we highly recommend you to try some of the passwords below to see why they are no good choices:

- password
- johnsmith
- 2018/10/4
- 1992home
- abcabc
- fffget
- poiuz
- @dmin

Password

☐ Show password

Submit

The password I chose to use was: \$\$hellovViN6@,!IPc(4&

How long could it take to brute force your password?

In this assignment you have to type in a password which is strong enough (at least 4/4).

After you finished this assignment we highly recommend you to try some of the passwords below to see why they are no good choices:

- password
- johnsmith
- 2018/10/4
- 1992home
- abcabc
- fffget
- poiuz
- @dmin

✓

Password ☐ Show password

Submit

You have succeeded! The password is secure enough.

Your Password: *****

Length: 21

Estimated guesses needed to crack your password: 2490000000099999700

Score: 4/4

Estimated cracking time: 7895738204 years 100 days 4 hours 26 minutes 8 seconds

Score: 4/4

Estimated cracking time in seconds: 7895738204 years 100 days 4 hours 26 minutes 8 seconds